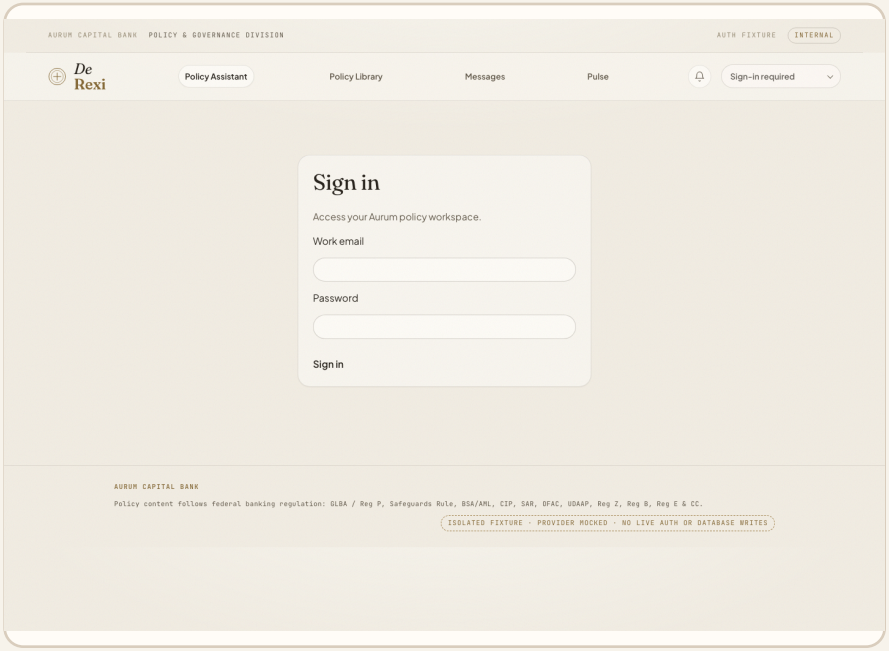
WEEK 09 / SECURITY & USER AUTHENTICATION

SECURE THE **POLICY WORKSPACE.**

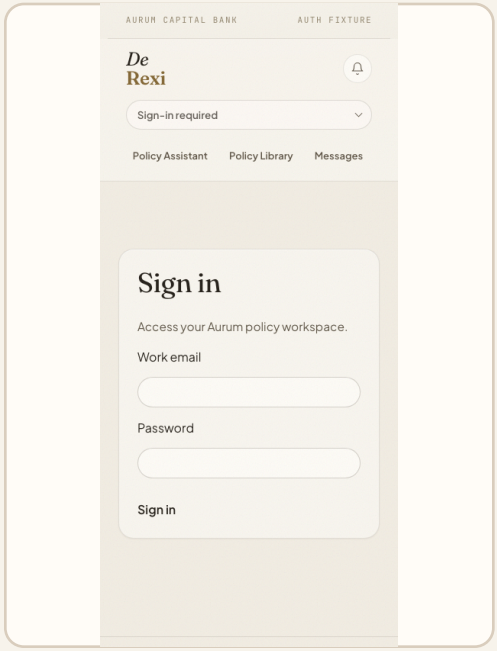
Authentication, role-aware access, security-event logging and document-processing safeguards for DeRexi.

414 FINAL PASSING CHECKS

0 failed / 0 blocked / 8 verification suites



01 Authentication screen / desktop



02 Mobile sign-in

Completion assessment: Security controls implemented and tested in isolated development fixtures. Production identity activation, live RLS validation and deployment encryption remain outstanding.

Evidence date: November 10, 2026. Figures are labeled AUTH FIXTURE and do not demonstrate live Supabase sign-in or production database writes.

ARCHITECTURE & CONTROLS

A secured application boundary

Week 9 built on verified JWT, messaging and Governance controls rather than replacing working modules.

01 Authentication & session handling

Backend-mediated Supabase password sign-in, refresh and logout were implemented with mocked provider tests. Production cookie settings use HttpOnly, Secure and SameSite Strict. Verified subject-to-business-user mapping prevents email-only identity assumptions.

02 Role-based access control

Anonymous requests are denied on sensitive routes. Employees receive personal records; Policy Owners receive authorized departmental information; System Administrators retain organization-wide oversight and incident controls. Policy self-approval remains forbidden.

03 Security events & safe responses

Structured events cover sign-in failures, authorization denials, changes, approvals and admin actions. Request IDs, throttling, CSRF protections, sanitized error responses and production HTTPS/HSTS configuration were tested. Sensitive values are excluded from logs.

04 Separation of environments

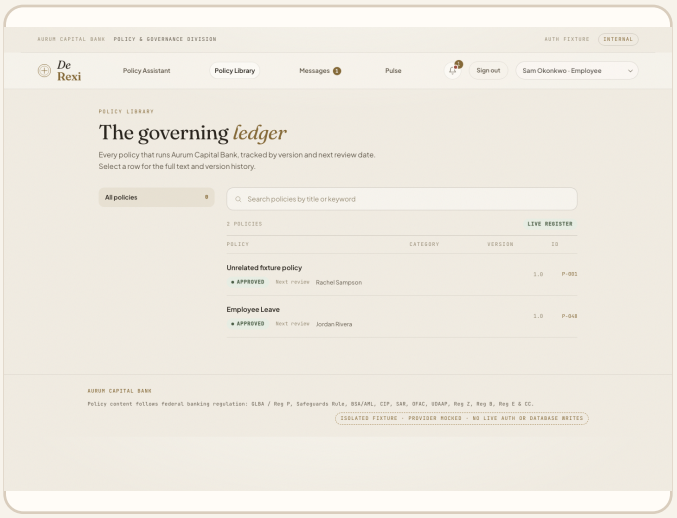
Developer personas are restricted to explicit opt-in development/test environments and loopback checks. Real provider sessions were simulated; production login and durable logging were not activated.

Design principle: Server authorization must stand independently of hidden navigation. Tests explicitly reject anonymous access, direct policy-write bypasses, unauthorized incident changes and self-approval.

INTERFACE EVIDENCE / PROTECTED VIEWS

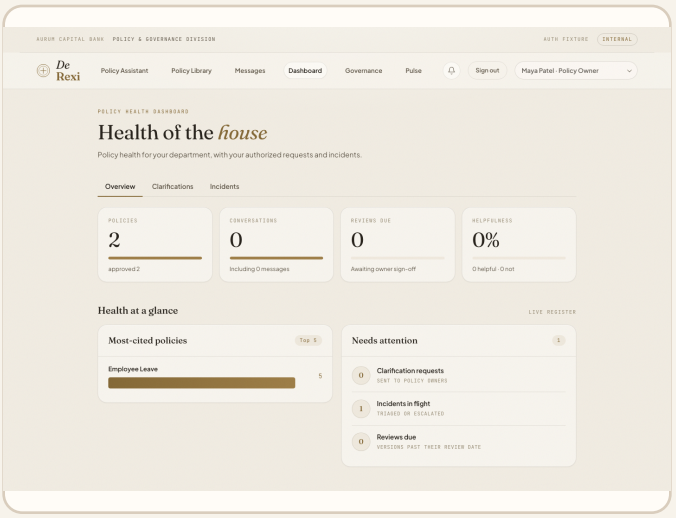
Authorization, visible by role

Screenshots demonstrate the same DeRexi design language across distinct, isolated role sessions.



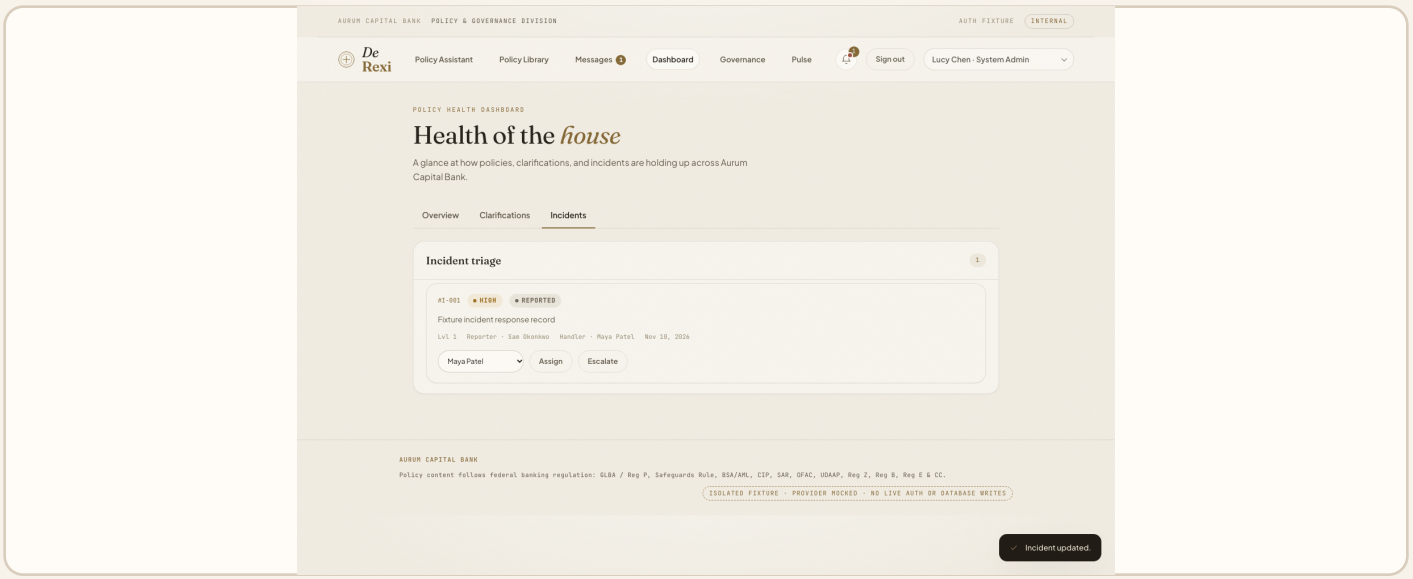
EMPLOYEE / POLICY LIBRARY

Approved policy content remains available to the employee; administrative navigation is not shown.



POLICY OWNER / DEPARTMENT DASHBOARD

Owner metrics and policy-health information are restricted to their authorized department.



SYSTEM ADMINISTRATOR / INCIDENT TRIAGE

The admin incident view demonstrates an authorized fixture assignment action, with incident status and feedback visibly updated. All three examples use synthetic records and mocked authentication.

TEST RESULTS / DOCUMENT IMPORT PROTECTION

Verification & parser recovery

Eight reported suite results total 414 passing checks. Some are prior regression results reused in the final evidence; this is not 414 newly executed tests.

SUITE	PASS	FAIL	BLOCK
Week 9 API / auth / logging / TLS	110	0	0
JWT foundation	24	0	0
Messaging workflow	73	0	0
Messaging security edges	29	0	0
Governance lifecycle	102	0	0
Browser / role / mobile	15	0	0
Document parser	47	0	0
Resource-limit protections	14	0	0

THE MACOS PARSER FIX

Initial parser execution was blocked by missing packages and then failed when macOS rejected a 256 MiB RLIMIT_AS setting. After installation of pypdf 6.21.4 and defusedxml 0.7.1, the resource-limiting implementation was adjusted for portability.

Final focused result: 47 parser tests, 14 resource-limit checks and 134 security/JWT regression checks passed (195 checks in that focused rerun). macOS uses a separate supervisor with 10 ms sampling, a 256 MiB threshold and timeouts; transient overshoot remains possible. Native Windows and Linux execution was not verified.

The earlier parser failure is resolved in the macOS test scope.

PRODUCTION READINESS / DECISION LOG

Boundaries of the current result

The completed local implementation is meaningful evidence of Week 9 progress. It is not a certification of production deployment, data confidentiality or regulatory compliance.

VERIFIED IN OBSERVED DIAGNOSTICS

TLS 1.3 between application client and Supabase pooler (AES-256-GCM cipher); isolated authorization, sign-in, logging and parser behavior.

NOT YET ACTIVATED

Zero live Supabase Auth users were observed. Live provider URL/public key/subject mapping, HTTPS origin and production sign-in/refresh/logout remain unconfigured or untested.

DATABASE ACCESS RISK

The inventory found 15 RLS-enabled public tables, an RLS-bypassing backend role, eight unconditional authenticated SELECT policies, and 90 direct-client grants. Backend RBAC does not constrain direct Data API access.

ENCRYPTION AND OPERATIONS

The backend reported no TLS for the internal PostgreSQL hop. Certificate/hostname verification, storage/backup encryption, production HTTPS, durable security logs and alerts remain unverified. No message-field or end-to-end encryption is claimed.

APPROVAL REQUIRED BEFORE LIVE ONBOARDING

Review the Week 8 Governance migration, eight-owner seed and approval-only BFF / RLS access-boundary proposal separately. None of these scripts were run as part of Week 9.

Week 9 status: Development/test scope complete (414 pass / 0 fail / 0 blocked). Production activation, direct-client database restrictions, full-path encryption assurances and real-user verification remain pending approval.